

패스키로 잠근 나만의 서랍

1번째 과제에서 만든 온라인 포트폴리오는 그대로 두고, 그 아래에 나만 보는 서랍을 하나 새로 만들어 비밀번호 없이 패스키(WebAuthn)로 잠근 결과물. "막았다"는 문장 대신 막힌 요청과 통과한 요청을 로컬 임시 서버·실제 Render 배포본·실기기 세 갈래로 남긴 기록

제출자	김대훈
제출일	2026년 9월 14일
결과물	chacha1650a.github.io/assignment-repository/8번째 과제(패스키 등록)/index.html
소스	github.com/chacha1650a/assignment-repository
인증 서버	daehoon-passkey-backend.onrender.com

01

무엇을 만들었나

1번째 과제에서 만든 온라인 포트폴리오는 한 줄도 고치지 않고 그대로 두었습니다. 그 아래에 나만 보는 서랍을 하나 새로 만들어 패스키(WebAuthn)로 잠갔습니다. 비밀번호는 만들지 않았습니다 — 이 제출물 어디에도 비밀번호를 입력하는 칸이 없습니다.

카드	요구사항	구현
1	공개 영역과 비공개 영역 분리	index.html:264 경계선, :280 비공개 서랍. 로그인 전 페이지 소스에 비공개 내용 0건(T08-C18), 무인증 요청은 401(T08-C16-17)
2	패스키 등록 — 공개키만 서버에 저장	@simplewebauthn/server 14.0.1 + 직접 짠 challenge 테이블. 등록마다 challenge 값이 서로 다르고, 저장되는 값이 공개키(비밀번호 아님)라는 것을 기록으로 확인
3	패스키 로그인 — 매번 새 질문	로그인마다 새 challenge 발급, 저장된 공개키로 서명 검증. 이미 쓴 질문 재사용은 400으로 거절
4	패스키 2개 등록 + 분실 대비	목록 화면에서 등록일과 함께 2개 확인, 하나 삭제 후 남은 것으로 로그인 성공. 마지막 패스키는 삭제 금지(409)
5	거절 증거 4종 + 설명서 6항목	로그인 없이 열기 · 남의 패스키로 열기 · 질문 재사용 · 삭제 뒤 로그인 네 가지를 요청·응답으로 확인. 인증 구현 설명서를 ①~⑥ 여섯 항목으로 작성

왜 과제 폴더 안에 백엔드가 없나 — Render 같은 호스팅은 배포 경로에 한글·괄호를 받지 못해서, 패스키 백엔드(Express + node:sqlite + @simplewebauthn/server)는 저장소 루트의 passkey-backend/ 라는 별도 영문 폴더·별도 서비스로 새로 배포했습니다. 1번·6번·7번 과제 폴더와 백엔드는 그대로 두어, 이전 제출물이 지금도 그대로 열립니다.

02

무엇으로 붙였고, 왜 그걸 골랐나

직접 구현 + 널리 쓰이는 라이브러리를 섞었습니다. Firebase Authentication·Auth0 같은 인증 서비스는 쓰지 않았습니다.

맡긴 일	무엇으로	이름과 버전
등록·로그인 응답 검증(CBOR·COSE·서명·origin/RP ID 확인)	라이브러리	@simplewebauthn/server 14.0.1
일회용 질문(challenge)을 만들고 한 번만 쓰이게 관리	직접 구현	challenges 테이블 + saveChallenge()/consumeChallenge() (server.js:122,132)
로그인 상태 유지(세션)	직접 구현	node:crypto randomBytes(32) + HMAC-SHA256 (server.js:102,106)
브라우저 쪽 WebAuthn 호출	직접 구현	passkey.js — navigator.credentials 직접 호출, 브라우저용 라이브러리 미사용
웹 서버 / CORS / 환경변수	라이브러리	express 4.21.2 · cors 2.8.5 · dotenv 16.4.5
데이터베이스	Node 내장	node:sqlite (Node 22.13+ 내장, 별도 설치·빌드 없음)

로그인 뒤 사람을 알아보는 방식: 세션(서버 저장 토큰). JWT가 아닙니다.

서명 확인에 성공하면 256비트 난수 토큰을 한 번 건네고, 서버는 토큰 원문이 아니라 HMAC-SHA256(토큰, SESSION_SECRET) 값만 저장합니다. 브라우저는 이후 모든 요청에 Authorization: Bearer 헤더를 붙이며(URL에는 실지 않음) sessionStorage에 둡니다. 만료는 발급 12시간, 로그아웃하면 서버가 revoked_at을 찍어 즉시 끊습니다.

검증은 왜 직접 짜지 않고 라이브러리를 골랐나

패스키 응답 확인은 CBOR로 감싼 attestationObject를 풀고, RP ID 해시·플래그·서명 횃수를 끊어 읽고, COSE 공개키를 해석하고, clientDataJSON의 type·challenge·origin을 맞춰본 뒤에야 서명을 검증합니다. 하나만 빼먹어도 "서명이 늘 통과하는" 서버가 되므로, 이미 여러 사람이 들여다본 구현에 맡겼습니다. (7번 과제에서 비밀번호 해시를 직접 만들지 않고 bcryptjs를 쓴 것과 같은 이유입니다.)

질문(challenge) 관리와 세션은 왜 직접 짰나

라이브러리는 expectedChallenge를 받기만 할 뿐, 그 값을 어디에 두고 언제 버릴지는 서버가 정해야 합니다. 이 과제의 핵심("매번 새 질문이 오고, 이미 쓴 질문은 다시 통하지 않는다")이 정확히 그 자리라 직접 만들었습니다. 세션도 JWT 대신 서버 저장 토큰으로 정했는데, 로그아웃을 진짜로 끊어야 "로그아웃 뒤 같은 값으로 요청하면 거절된다"를 말이 아니라 응답으로 보일 수 있기 때문입니다.

03

어디를 어떻게 고쳤나

네 흐름이 소스의 어디를 지나는지입니다.

흐름	화면	서버
등록	passkey.js:243 registerPasskey()	server.js:254 /register/options · :325 /register/verify
로그인	passkey.js:325 loginWithPasskey()	server.js:430 /login/options · :465 /login/verify
로그아웃	passkey.js:376 logout()	server.js:532 /api/auth/logout → revokeSession()
비공개 자료 조회	passkey.js:200 refresh()	server.js:581 /api/private/items (문지기: :162 requireAuth())

거절을 만들어 내는 소스의 위치

무엇을 막는가	어디	응답
로그인 없이 비공개 자료	server.js:162 requireAuth()	401 unauthorized
로그아웃한 토큰	server.js:177 (revoked_at 검사)	401 unauthorized
이미 쓴 질문 재사용	server.js:132 consumeChallenge()	400 challenge_already_used
서명이 틀림	server.js:495 verifyAuthenticationResponse()	401 bad_signature
등록된 적 없는 지워진 패스키	server.js:490 (credential 조회 실패)	401 unknown_credential
남의 자료 읽기	server.js:581 — req.user.id만 사용	200이지만 내 것만
남의 자료·패스키 지우기	server.js:557, :611 — AND user_id=?	404 not_found
마지막 패스키 삭제	server.js:569	409 last_passkey
패스키 0개 계정 재등록	server.js:274	403 account_locked

화면에서 감춘 것이 아닙니다. index.html:264가 공개/비공개 경계선, :280이 비공개 섹션입니다. 비공개 내용은 HTML에 들어있지 않습니다 — 로그인 전 index.html을 그대로 받아 봐도 서랍 안 항목이 한 건도 없습니다(T08-C18). 서버가 로그인 뒤에만 내려줍니다(T08-C15).

04

안 열리는 것을 확인한 기록

네 가지를 모두 확인했고, 성공한 요청과 거절된 요청을 나란히 두었습니다. 같은 시나리오를 로컬 임시 서버(증거/자동 검증 기록.md, 28가지) · 실제 Render 배포본(증거/배포 서버 검증 기록.md, 27가지) · 실제 기기·브라우저(증거/실기기 검증 기록.md) 세 갈래로 남겼습니다.

확인 1 — 로그인 없이 열기

	요청	응답
거절	GET /api/private/items (토큰 없음)	401 unauthorized · "패스키로 들어와야 볼 수 있어요."
거절	GET /api/private/items + 지어낸 토큰	401 unauthorized
성공	GET /api/private/items + 패스키로 받은 토큰	200 count:4, items [...]

확인 2 — 남의 패스키로 열기 (양방향)

	요청	응답
거절	계정 A의 credentialId + 다른 개인키로 서명	401 bad_signature
거절	A 토큰으로 ?handle=tester-b 요청	200이지만 owner: daehoon-a (내 것만)
거절	반대 방향: B 토큰으로 ?handle=daehoon-a	200이지만 owner: tester-b
거절	DELETE 남의 항목/패스키 — 내 토큰으로	404 not_found
성공	각자 자기 토큰으로 자기 자료 조회	A 4건 / B 4건, 내용 서로 다름

확인 3 — 이미 쓴 질문 재사용

	요청	응답
성공	새 질문으로 로그인	200, 토큰 발급
거절	같은 질문으로 한 번 더 로그인	400 challenge_already_used
거절	화면이 지어낸 질문으로 로그인	400 challenge_unknown

확인 4 — 패스키 삭제 뒤 로그인

	요청	응답
성공	패스키 2개 등록 → GET /api/passkeys	200 count:2, 이름·등록일 표시
성공	두 번째 삭제 → 남은 첫 번째로 로그인	200, 토큰 발급
거절	지운 패스키로 로그인 (개인키는 기기에 남음)	401 unknown_credential
거절	마지막 하나 남은 패스키 삭제	409 last_passkey

이 보고서를 쓰는 시점에 직접 다시 재현한 결과 — 배포본 GET (공개 페이지) → 200, GET daehoon-passkey-backend.onrender.com/api/private/items (토큰 없음) → 401 {"error": "unauthorized", "message": "패스키로 들어와야 볼 수 있어요."}, 로그인 전 페이지 소스에서 "복구 코드"·"가상의 회사"·type="password" 모두 0건. 위 표와 완전히 같은 결과였습니다. 기록에서 세션 토큰은 앞 8글자만 남기고 가렸습니다(T08-C34).

05

검증하며 찾아낸 것 — 실기기에서만 드러난 문제

자동 검증(가상 인증기)으로는 끝내 나오지 않았고, 실제 아이폰으로 눌러 보다 계정 하나가 잠긴 뒤에야 찾은 문제입니다.

항목	내용
증상	같은 계정에 두 번째 패스키를 등록했는데, 하필 쓸 수 있는 쪽을 지우자 그 계정에 영영 못 들어가게 됨
원인	비밀번호 관리자(구글 비밀번호 관리자·iCloud 키체인)는 패스키를 (사이트+사용자 식별자) 한 쌍으로 묶어 보관함. 같은 관리자에 두 번째를 만들면 "같은 사이트의 같은 사용자"로 보고 첫 번째를 조용히 대체함 — 서버 DB에는 공개키가 2줄 남아 "패스키 2개"로 보이지만, 기기에 실제로 남은 개인키는 1개뿐
실제 결과	daehoon 계정은 서버에 공개키가 1개(DE5n1hnpmbtf...) 남았는데, 아이폰에는 짝이 되는 개인키가 없어 들어갈 수 없는 상태가 됨
지금 해 둔 것	서버 동작은 표준대로 유지(사용자 식별자를 계정마다 하나로 두는 것이 맞음). 패스키 목록 옆에 상시 경고 "두 번째 패스키는 반드시 다른 기기나 다른 비밀번호 관리자에 만드세요"(index.html:382, .col-warn-replace)를 추가하고, 추가 등록 버튼을 누르면 확인 창을 한 번 더 띄움(passkey.js)
그래도 못 막는 것	사용자가 어느 관리자를 골랐는지 서버는 알 수 없음. 등록 응답에는 credentialBackedUp(기기 밖 동기화 여부) 정도만 담기고 어느 관리자인지는 오지 않아, "두 번째가 첫 번째를 덮어썼다"를 서버가 감지할 방법이 없음. 제대로 막으려면 삭제 전 "남길 패스키로 지금 로그인해 보라"를 요구해야 함

자세한 요청·응답과 확인 과정은 증거/실기기 검증 기록.md의 "확인하면서 찾아낸 것 2"에 그대로 옮겨 두었습니다.

06

아직 못 막은 것

"없습니다"로 적지 않았습니니다. 실제로 남아 있는 한계입니다.

못 막은 것	왜 위험한가 / 지금 상태
① 계정 이름 선점 — 가장 큰 구멍	처음 등록하는 사람이 그 이름의 주인이 되는 구조라, 남이 먼저 같은 이름으로 등록하면 그 이름을 다시 쓸 수 없음. 서랍 내용은 새지 않지만 이름 선점 자체는 못 막음. 초대 코드·이메일 확인 같은 절차가 필요하나, 이번 과제는 비밀번호 없는 흐름 자체에 집중하려 넣지 않았음
② 세션 토큰 탈취	XSS가 생기면 sessionStorage의 토큰을 읽어 갈 수 있고, 만료(12시간)까지 통함. escapeHtml() 처리, URL 미노출, 로그아웃 즉시 차단까지는 해두었지만 토큰을 기기에 묶는 일(HttpOnly 쿠키 등)은 못 함
③ 질문(challenge)을 120초 보관	지문·PIN 입력 시간을 주려 넉넉히 잡았는데, 그만큼 가로챈 질문을 써 볼 창이 길어짐. 재사용 자체는 막히지만 보관 시간은 더 줄일 수 있음
④ 서명 횟수(counter) 저장만 하고 검사 안 함	복제 탐지용 값인데, 클라우드 동기화 패스키 다수가 counter를 0으로 고정 전송해 검사를 켜면 정상 로그인인 거절되어 고고 있음. 복제는 못 잡음
⑤ 요청 횟수 제한 없음	로그인 옵션 요청을 초당 수백 번 불러도 막지 않음(서명이 있어야 하므로 로그인 자체는 안 풀리지만 서버가 지칠 수 있음). 5분 주기 청소만 있음
⑥ 재배포하면 패스키가 사라짐	Render 무료 플랜 디스크는 영구 저장이 아니라, 재배포 시 passkey.db가 초기화됨. 새 이름으로 다시 등록해야 함
⑦ 등록 시 기기 증명서를 받지 않음	attestationType: 'none'이라 "이 패스키가 정말 그 회사 보안 키에서 나왔는가"는 확인 못 함. 개인 포트폴리오엔 불필요하다고 판단했지만 기업 환경이라면 채워야 할 자리

07 시와 나

구분	내용
AI에게 맡긴 일	WebAuthn 표준에서 서버가 확인해야 하는 항목(RP ID 해시·플래그·origin-type·challenge·서명) 훑기, @simplewebauthn/server v14 API 확인. challenges/credentials/sessions/private_items 네 표의 첫 설계안과 express 라우트 빼대. 가상 인증기(virtual-authenticator.js) 작성 — 실제 패스키는 사람이 지문을 눌러야 만들어져 같은 확인을 수십 번 자동으로 돌릴 수 없어서, 기기가 하는 일(P-256 키쌍 생성, authenticatorData 조립, CBOR 인코딩, 서명)을 표준대로 흉내 내는 코드를 맡김. 확인 시나리오를 돌려 요청·응답을 그대로 옮기고 토큰을 가리는 스크립트, 이 문서와 검증 안내서 초안
내가 직접 판단한 일	비밀번호 재설정·이메일 확인 같은 우회로를 하나도 만들지 않기로 한 것. 마지막 패스키는 삭제 금지(409), 패스키 0개 계정은 재등록도 금지(403)로 정한 것. 질문(challenge) 관리만은 라이브러리에 맡기지 않고 직접 짰 것. 세션을 JWT가 아니라 서버 저장 토큰으로 정한 것(로그아웃을 진짜로 끊기 위해). 서랍 내용을 전부 지어낸 것으로 채운 것. 1번 과제의 style.css-script.js를 건드리지 않은 것. 자동 검증을 다 통과한 뒤에도 실제 아이폰으로 끝까지 눌러 보기로 한 것 — 그 덕분에 5절의 문제를 찾음
AI 제안을 따르지 않은 일	① "비공개 항목을 HTML에 미리 넣고 로그인 전엔 CSS로 감추자"는 초안을 버림 — 페이지 소스에 그대로 남아 개발자 도구로 다 보이기 때문. 로그인 뒤 GET /api/private/items로만 내려오게 고침. ② "등록이 끝나면 곧바로 세션 토큰도 같이 내주자"는 제안을 따르지 않음 — 로그인 서명을 한 번 더 거쳐야 "로그인할 때도 매번 새 질문에 서명한다"가 실제로 일어남. ③ "편의를 위해 계정 이름 없이 discoverable credential만 쓰자"는 이번엔 미룸 — 계정 A·B를 갈라 서로의 자료가 안 보이는 것을 보이기에 이름을 받는 편이 분명했음. ④ 계정 존재 여부가 드러나는 실패 문구는 쓰지 않음

부록

제출 주소와 공개 범위

항목	내용
결과물	chacha1650a.github.io/assignment-repository/8번째 과제(패스키 등록)/index.html — 계정 없이 새 시크릿 창에서 열리며, 첫 화면은 1번 과제의 공개 소개 페이지
소스	github.com/chacha1650a/assignment-repository — 화면은 8번째 과제(패스키 등록)/, 서버는 passkey-backend/
인증 서버	daehoon-passkey-backend.onrender.com (Render 무료, render.yaml Blueprint 배포). 무료 서버라 15분 이상 유휴 시 잠들어 첫 요청만 30~60초 걸릴 수 있음
공개 범위	공개 소개 페이지까지는 누구나. 서랍 내용은 그 서랍의 패스키로 들어온 사람만. 심사자는 등록·로그인을 직접 해 볼 필요가 없음
저장 위치	Render에 배포한 자체 백엔드의 node:sqlite. 계정별 user_id로 분리. 무료 플랜 디스크는 영구 저장인 아니라 재배포 시 초기화됨(⑥ 항목)
비밀값 취급	제출물 어디에도 비밀번호·세션 토큰·서버 비밀키 원문 없음. 토큰은 앞 8글자만 남기고 ...(생략), SESSION_SECRET은 환경변수에만 존재. 개인키는 애초에 요청에 실리지 않아 가릴 것이 없음

심사하시는 분께. 제 서랍을 열어 보실 필요가 없습니다. 페이지를 끝까지 내려 공개/비공개 경계선과 잠긴 서랍을 확인하시고, 원하시면 계정 이름 칸에 아무 영문 이름을 넣고 "패스키 새로 만들기"를 눌러 보시면 됩니다 — 그 계정에는 제 내용이 한 건도 보이지 않는 것이 정상이며, 그것이 이 과제의 요점입니다. 요청·응답 전문은 증거/자동 검증 기록.md · 증거/배포 서버 검증 기록.md · 증거/실기기 검증 기록.md에 그대로 들어 있습니다.